

12. Assess documentation standards. Consider management's process for
 - a. Maintenance of documentation for internally developed programs and externally procured products and services.
 - b. Maintenance of necessary information and documentation to understand and convey how a system or component was developed, how it functions, and where appropriate security and resilience points are included.
 - c. Maintenance of detailed documentation for each system and component in development and production.
 - d. Implementation of established policies to prepare documentation before deployment and additionally when appropriate, such as when management makes changes.
 - e. Obtaining documentation from the third party and incorporating it into the entity's own stored documentation for acquired systems and components.
 - f. Validating before purchase (through an internal review or a third-party certification) that a procured system's documentation meets the entity's documentation needs and standards.

13. Assess management's post-implementation review processes. Consider effective evaluation of development, acquisition, and maintenance projects and management actions, such as
 - a. Conducting post-implementation reviews at the end of a project to validate completion of project objectives and assess development activities.
 - b. Interviewing key stakeholders actively involved in the operational use of a product to determine effectiveness of the completed project.
 - c. Documenting and addressing any identified problems to improve future projects and remediate issues in current projects.
 - d. Analyzing effectiveness of project management activities by comparing, among other things, planned and actual costs, benefits, risks, return on investment information, and development time frames.
 - e. Documenting results and presenting them to senior management and determining who should be informed of any operational or project management deficiencies.

Objective 5: *Evaluate whether management has developed and followed consistent processes to identify risks and oversee IT projects to address any risks identified. IT projects should be managed according to the size and complexity of the entity and its project characteristics and risks. (Section IV.N "[IT Project Management](#)")*

For this objective, examiners should review and assess

- Project plans, proposals, and status reports to determine whether the IT project manager works with stakeholders (e.g., PMO) to oversee and carry out IT projects.
- Board and committee minutes to evaluate whether management reviews and prioritizes projects and whether it considers the project's effect on operations and the entity's needs.

- Project plans, project requests, and documentation standards to determine whether they are structured appropriately to clearly define the project purpose, entity's requirements, and include deliverables for each project phase to address business needs.
 - Documentation of management approvals of any addition or modification of functional, security, or control features and demonstration that changes are aligned with the project charter and project plan.
 - Testing and quality management plans used to validate that the project meets the entity's project goals and stakeholder requirements.
 - Documentation for the closeout of the entity's IT projects.
1. Assess whether management develops and follows consistent processes to identify risks and oversee IT projects to address any risks identified. Consider whether management
 - a. Establishes project management policies, standards, and procedures that apply enterprise-wide.
 - b. Develops and follows consistent processes to identify risks and oversee IT projects to address any risks identified.
 - c. Considers the project's effect on operations and the entity's needs (e.g., IT, information security, lines of business, customer needs, and regulatory and legal compliance) when reviewing and prioritizing projects.
 - d. Performs analysis of system or component needs for a given project.
 - e. Monitors changes for any addition or modification of functional, security, or control features to help ensure that these changes are approved and aligned with the project charter and project plan.
 - f. Develops and executes testing plans, which validate whether the entity's project goals and stakeholder requirements are met.
 - g. Maintains comprehensive and accurate documentation reflecting the testing methodology employed, actual tests performed, and test results throughout the testing process.
 - h. Implements quality management (also may be referred to as QA and QC) processes to help ensure that project requirements are met and validated.
 - i. Defines and maintains the required elements for documentation of the closeout of the entity's IT projects.
 - j. Establishes standards and maintains appropriate documentation for IT projects to foster a consistent and accurate process across projects.
 - k. Maintains processes for developing IT project plans that describe existing system benefits and weaknesses and explain project objectives.

Objective 6: *Evaluate whether management has an SDLC to manage systems and system components throughout their life cycle; to achieve the objectives of confidentiality, integrity, availability, and resilience; and to meet the entity's business objectives. (Section IV.O "[System Development Life Cycle](#)")*

For this objective, examiners should review and assess

- The documented management and control processes for development.

- Description and detail of entity SDLC-related controls, including for supply chain partners.
 - Responsibility and accountability assignment.
 - Key stakeholder involvement.
 - Clear evidence of stakeholder communication and tracking of all SDLC phases and actions.
1. Assess management's oversight of the SDLC process. Consider management's implementation of a documented process, such as an SDLC, used to manage and control development activities, if the entity engages in internal development activities.
 2. Evaluate management's maintenance of protections (e.g., information security and resilience) in the information systems, components, and networks for data in transit and at rest, including for the entity's and supply chain partners' information, through all phases of the SDLC.

Objective 7: Evaluate whether management implements effective processes to address the plans and actions needed in each phase of an IT project, as part of the SDLC. (Section IV.O.1 "[SDLC Phases](#)")

For this objective, examiners should review and assess the activities associated with the entity's SDLC phases, such as the following example phases:

Initiation Phase

- Description of the project's purpose, expected benefits, support for entity business objectives, and any legal and regulatory requirements.
- Plans for addressing additional costs, resource needs, and alternate solutions.
- Validation of initial impact analysis, including any baseline security concerns.
- Documentation of the project proposal for all stakeholders in the supply chain.

Development or Acquisition Phase

- Documentation of design specifications.
- Documentation of mitigation strategies for risks identified in the impact analysis.
- Risk assessments, baseline controls design, and effectiveness of security controls.
- Documentation of initial development testing, conversion, implementation, and training plans, including confirmation of the functionality and controls.
- Documentation of additional design requirements and development changes.
- Documentation of draft user, operator, and maintenance manuals.

Implementation and Assessment Phase

- Documentation of design reviews and system tests, including any new specifications.
- Documentation of deployment approach selected.
- Training provided, including user and system support documentation.
- Post-implementation review, including any configuration changes.

Operations and Maintenance Phase

- Documentation of performance and controls monitoring.
- Documentation of configuration and change management controls and proposed changes.
- ITAM inventory and associated risk assessments.

Sunset and Disposal Phase

- Plans and validation measures for accessible data retrieval from archives.
 - Documentation of off-boarding procedures, including for third-party providers.
 - Documentation of a post-disposal review, including processes and lessons learned.
1. Assess management's oversight of SDLC phases. Consider whether management
 - a. Understands the SDLC phases and the actions in each phase.
 - b. Identifies the actions and assign responsibility and accountability for completing those actions.
 - c. Defines the phases that will be included in the entity's SDLC and helps ensure the completion of each phase to promote transparency and accountability for, and agreement and acceptance by, the stakeholders.
 2. Assess management's actions during the initiation phase of the SDLC. Consider management's actions to
 - a. Describe the development project's purpose, identify expected benefits, and explain how the proposed system or component supports the entity's objectives.
 - b. Address legal and regulatory requirements.
 - c. Identify alternative solutions and explain the entity's confidentiality, integrity, availability, and resilience requirements.
 - d. Consider and address any potential baseline security concerns during this phase by performing an initial impact analysis.
 - e. Address planning items, including the following:
 - Responsibilities of third-party service providers, internal audit, information security, and IT staff.
 - Established acceptance criteria for each SDLC phase.
 - Established review and approval procedures to help ensure that development teams complete all SDLC phase or independent sprint requirements before moving into subsequent phases.
 - Identify control and security features to be designed, built or acquired, and implemented.
 - Create processes for development and change management to minimize disruptions to the development process.
 - Create processes that address project methodology selection, approval authority, and risk management procedures.
 - Identify costs associated with project overhead (e.g., office space, hardware, and software used during the project) as well as soft costs in budgeting personnel expenses and outsourced activities.

- f. Consider input from all stakeholders.
 - g. Evaluate the appropriateness of each requested functional requirement.
 - h. Consider all proposals and analyze them to determine whether to develop or acquire the system or component.
3. Assess management's actions during the development or acquisition phase of the SDLC. Consider management's actions to
 - a. Determine other functionality, such as whether the configuration of the system or component (e.g., an IoT product) is possible, whether the system or component can be restored to a secure default setting, and whether there are restrictions on users or services that can make changes.
 - b. Consider the results of the impact analysis performed in the SDLC initiation phase and review those results throughout the SDLC.
 - c. Address or mitigate concerns from the impact analysis or new concerns that present risk beyond the board's risk appetite.
 - d. Conduct a risk assessment and use the results to design baseline controls to meet the entity's requirements.
 - e. Build in appropriate controls, including for network interfaces, to any products the entity develops or acquires to maintain confidentiality, integrity, availability, and resilience throughout the supply chain.
 - f. Review the appropriateness of new or modified design requirements or development changes and monitor for and minimize scope creep.
4. Assess management's actions during the implementation and assessment phase of the SDLC. Consider management's actions to
 - a. Perform design reviews and system tests before implementation of the system or component to ensure that all entity specifications are met.
 - b. Perform additional acceptance tests if new features or controls are added to the system or component.
 - c. Use and document the results of the design reviews and system tests, update documentation after performing new reviews or tests, and maintain test results for future review and use.
 - d. Determine the appropriate implementation strategy for the entity and system or component being deployed.
 - e. Coordinate training logistics, including who should be trained, what the training involves, and when training should be conducted.
 - f. Organize a training and awareness campaign, and notify users of any implementation and training responsibilities.
 - g. Perform a post-implementation review once the product is implemented.
 - h. Validate the initial impact analysis during the post-implementation review and report on any changes to the results.
 - i. Confirm that the implementation occurred as planned, and determine whether there were any unanticipated effects of the change on existing controls.

- j. Validate whether configurations (e.g., security, functionality, or performance) on the new system are appropriate.
5. Assess management's actions during the operations and maintenance phase of the SDLC. Consider management's actions to
 - a. Monitor performance of a system or component to help ensure that it is consistent with pre-established user, security, and other entity requirements, and making necessary modifications.
 - b. Conduct configuration management and control activities and document any proposed or actual changes in the entity's security or operational plan of the system or component.
 - c. Assess and document changes in the entity's ITAM inventory and related risk assessments.
 - d. Follow established change management policies, standards, and procedures to minimize the potential of a modification disrupting or degrading operations.
 - e. Perform operations and maintenance phase tasks regardless of whether entity personnel or a third party performs them.
6. Assess management's actions during the sunset and disposal phase of the SDLC. Consider management's actions to
 - a. Consider the need and plan for methods for future data retrieval before archiving information and if necessary.
 - b. Maintain archived data in an accessible and readable format, adhering to data retention guidelines.
 - c. Periodically validate the accessibility of the archived data or develop a plan to migrate potentially inaccessible data to an accessible format.
 - d. Maintain confidentiality, integrity, availability, and resilience throughout this phase.
 - e. Develop comprehensive off-boarding procedures if the system or component requiring disposal is managed by, or the related data are stored by, a third party.
 - f. Perform a post-disposal review at the end of the sunset and disposal phase that details the processes and lessons learned from shutting down and archiving the terminated system or component.

Objective 8: Evaluate management's third-party relationship risk management processes related to development, acquisition, and maintenance. (Section IV.P "[Third-Party Relationship Risk Management](#)")

1. Assess management's due diligence practices as part of its third-party selection and relationship risk management processes. Consider whether management
 - a. Identifies and documents any limitations of its due diligence, understands the risks from such limitations, and considers alternatives regarding how to mitigate development, acquisition, and maintenance risks.
 - b. Evaluates the conclusions from supplemental due diligence efforts, such as information derived from third parties (e.g., industry utilities or consortiums,

- consultations with other organizations, or engaging in joint efforts), based on the entity's own specific circumstances and performance criteria for the activity.
- c. Involves the board, through its oversight responsibilities, to ensure awareness of—and, as appropriate, request approval or delegated approval of—contracts involving higher-risk development, acquisition, and maintenance activities.

Objective 9: *Evaluate whether management implements policies to measure, monitor, and track changes and use all related information obtained to inform SCRM activities. (Section IV.Q “[Supply Chain Considerations](#)”)*

Examiners should review

- Policies, procedures, project plans, and SDLC procedures to determine whether SCRM activities are integrated into the SDLC for the entity and applicable third parties.
 - Control configurations and reports used by management to monitor, control, and protect communications at the key access points of supply chain information systems.
 - Architectural designs, software development techniques, and systems engineering principles that promote effective information security throughout the supply chain.
 - Topologies and process flow diagrams that identify interconnectivities and potential single points of failure, while also considering continuity and resilience.
 - Inventory and validation of documentation (e.g., due diligence, including contracts) for supply chain partners, as well as documentation for provenance of systems, components, and data.
 - Communication processes and documented communication of threat intelligence and vulnerability identification with supply chain partners.
 - Management's assessment of inauthentic or unapproved systems or components (e.g., counterfeit or shadow IT).
 - SCRM controls in maintenance-related situations, including monitoring for unauthorized modifications, communicating changes, and monitoring for EOL.
1. Assess implementation of policies for tracking changes and use of the obtained information to inform the entity's SCRM activities. Consider management's actions to
 - a. Ensure that SCRM activities are integrated into the SDLC for the entity and applicable third parties.
 - b. Monitor, control, and protect communications (i.e., information transmitted or received) at key access points (e.g., external boundaries and key internal boundaries) of supply chain information systems.
 - c. Use architectural designs, software development techniques, and systems engineering principles that promote effective information security in the supply chain.
 - d. Identify potential single points of failure among all entities in the entity's supply chain numerous interconnectivities and risks from all partners.
 - e. Identify and consider any nested third-party relationships through common ownership (e.g., affiliates, subsidiaries).

- f. Identify and consider risks related to supply chains by tracking interdependencies between all parties involved (e.g., owners and third-party service providers, including vendors) in the supply chain.
 - g. Consider any information pertinent to the security, integrity, resilience, quality, trustworthiness (e.g., not on the OFAC list, other concerns), or authenticity of their supply chain partners or products.
 - h. Evaluate supply chain partners consistently, based on available information, and depending on the specific context and purpose for which the assessment is being conducted, select additional factors for consideration.
 - i. Document the reference sources for assessment information to help establish the quality of information (e.g., its relevance, completeness, and accuracy) relied on for supply chain assessments.
2. Assess supply chain risk management practices. Consider management's processes and plans to analyze policies, standards, and procedures, which outline and describe an entity and third parties' processes for SCRM (including for subcontractors). Consider activities such as the following:
 - a. Maintaining a current and accurate inventory of all applicable suppliers and identify their criticality to the business.
 - b. Considering established national and international standards, as applicable, as a baseline for security requirements for the entity's supply chain.
 - c. Assessing and addressing supply chain risks associated with a given geographic location and apply appropriate risk responses (e.g., defining acceptable locations).
 - d. Defining roles and responsibilities for personnel (e.g., development, acquisition, and maintenance) to address various supply chain activities.
 - e. Providing general controls and processes.
 - f. Developing, documenting, and maintaining an accurate inventory of third parties that reflects the entity's key supply chain partners.
 - g. Considering configuration management minimum security requirements for the supply chain.
 - h. Applying appropriate configuration management controls to its own systems and encouraging or requiring the use of comparable controls by all parties in the entity's supply chain through contracts.
 - i. Understanding and mitigating all relevant risks associated with interdependencies throughout the various supply chains potentially affecting the entity.
 - j. Planning for resilience, including scenarios related to supply chain issues.
 - k. Documenting provenance for systems, components, and data, and monitoring for changes in the chain of custody that may increase risk to the entity throughout the SDLC.
 - l. Considering provisions for excess capacity, bandwidth, and redundancy in agreements with supply chain partners, and take appropriate mitigation action, as necessary.
 - m. Considering creation of SBOM for applicable and appropriate classes of software (e.g., purchased, open-source, and in-house developed software).

- n. Validating that existing SCRM capabilities (e.g., vulnerability management practices and vendor risk assessments) are not deprioritized under the mistaken assumption that SBOM replaces these activities.
- o. Ensuring the quality of information (e.g., its relevance, completeness, and accuracy) relied on for an assessment and documenting the reference sources for assessment information.
- p. Establishing effective project management processes that can help identify critical components, especially those that are used by multiple business lines, functions, systems, and components, such as the following:
 - Determine whether there is potential foreign ownership or influence, and whether the supply chain partner may have relationships with OFAC-sanctioned individuals, organizations, or countries.
 - Evaluate supply chain partner oversight of its subcontractors (i.e., fourth parties) or developers.
 - Identify the level of open-source systems and components used by the entity, and determine how the supply chain partner demonstrates its compliance with applicable open-source licensing agreements.
 - Conduct research on COTS systems and components (e.g., via publicly available resources) or request proof to determine whether the supply chain partner (e.g., OEM) has performed testing as part of their quality or security processes.
 - Use authorized resellers or distributors with an ongoing relationship with the supply chain partner for systems and components not directly acquired from an OEM entity.
 - Acquire directly from vetted OEMs or their authorized distributors and resellers when obtaining alternative sources for continued support.
 - Track chain of custody of systems, components, and underlying code as they move throughout the supply chain to minimize the potential for counterfeit or altered products.
- q. Communicating with its supply chain partners to promote awareness of threat intelligence and relevant vulnerabilities in the entity's supply chain to inform operational security processes.
- r. Monitoring for supply chain system and component security and threat intelligence alerts and advisories from supply chain partners and taking appropriate actions in response.
- s. Considering employment of techniques to introduce randomness into entity operations and assets in the entity's systems or networks.
- t. Considering concealment techniques, such as masking metadata that may be accessible in downloads or deliveries of systems and components, whether developed or acquired.
- u. Consulting with the entity's legal counsel and board, as appropriate, regarding advanced security protection techniques (e.g., misdirection, honeypots) beyond standard industry techniques (e.g., basic randomness and concealment) techniques before implementation, as they may present liability and additional risk to the entity.
- v. Considering incident response-related information (e.g., definition of an incident, roles, and responsibilities) in its agreements with its supply chain partners.

- w. Considering correlation of available threat information with potential threats and vulnerabilities.
- x. Considering implementation of advanced monitoring over activities performed by higher-risk personnel (e.g., users with elevated authority or privileges).
- y. Considering information-sharing clauses in agreements and contracts.
- z. Performing the following when implementing maintenance processes throughout the supply chain:
 - Defining agreements that identify roles, responsibilities, and practices that may be used for maintenance activities, especially when third parties are responsible for maintaining the entity's systems or components.
 - Monitoring for unauthorized modification or removal of the entity's systems or components (e.g., use of counterfeit systems and components, malware) in the supply chain.
 - Monitoring systems and components for planning for EOL to prepare for replacement or upgrade to the systems and components.
 - Considering any potential availability issues in the supply chain for systems and components, or providing agreements to continue support for legacy systems or components until a change can be made without significant disruption to operations.
- aa. Understanding and considering interconnectivities throughout the supply chain to effectively manage supply chain risks.
- bb. Incorporating third parties into business continuity and resilience activities throughout the supply chain, when applicable.
- cc. Considering use of available information, such as that provided by third-party user groups and associations, to augment ongoing monitoring and due diligence, threat intelligence, and security throughout the supply chain.
- dd. Implementing a process to validate the effectiveness of the security of systems and components throughout the supply chain when performing development, acquisition, and maintenance activities, and make appropriate adjustments to risk assessments to account for interconnectivity risk.
- ee. Considering risk management factors in the entire life cycle of a third-party relationship, including planning, due diligence, contract negotiation, ongoing monitoring, and termination.

Objective 10: Evaluate whether management implements sound processes for the development of systems and components supporting the entity's business needs and operations. (Section V "[Development](#)")

Examiners should review the following:

- Documentation of training in secure design and coding techniques for those responsible for development activities.
- Development standards, including procedures for managing changes and a back-out plan.
- Evidence of communication throughout the supply chain regarding identification of critical systems and components, potential threats and vulnerabilities, configurations, and responsibilities for selection and maintenance of system and network components.